

Guía Práctica de Triage y Respuesta a Incidentes

Manual de Campo y Cheatsheet para Analista SOC Junior (L1)

Especialidad: Cybersecurity / SOC L1

Temas: Web Logs, AD, Phishing, SPL & IR

Documento: Portafolio Técnico

1. Análisis de Web Logs (HTTP / IIS / Apache / Nginx)

El análisis de registros web permite identificar actividades de reconocimiento, escaneos automatizados e intentos de explotación sobre aplicaciones web.

Códigos de Estado HTTP Fundamentales en Triage

CÓDIGO	SIGNIFICADO	INTERPRETACIÓN PARA EL ANALISTA SOC
200 OK	Petición Exitosa	Atención si ocurre tras múltiples 404/401 o sobre archivos sensibles (ej. <code>.zip</code> , <code>.bak</code> , <code>/admin</code>).
401 / 403	No Autorizado / Prohibido	Intentos de autenticación fallidos o accesos denegados por ACL/WAF.
404 Not Found	No Encontrado	Ráfagas masivas en segundos indican escaneo automatizado (Gobuster/Dirbuster/ffuf).
500 Error	Internal Server Error	Común cuando un payload de Inyección SQL (SQLi) rompe la consulta en la base de datos.

Anatomía de una Línea de Log Maliciosa

```
192.168.1.50 - - [25/Aug/2026:10:15:30] "GET /products.php?id=1' UNION SELECT 1,2,version()-- - HTTP/1.1" 200 4522 "-" "sqlmap/1.5.2"
```

- **IP Origen** (`192.168.1.50`): Dirección desde donde se origina el ataque.
- **Payload / URI** (`id=1' UNION SELECT . . .`): ** Patrón claro de SQL Injection (SQLi).
- **Respuesta y Tamaño** (`200 4522`): El servidor respondió exitosamente y devolvió datos (posible exfiltración).
- **User-Agent** (`sqlmap/1.5.2`): Firma de herramienta automatizada de explotación.

2. Eventos de Windows & Active Directory (Autenticación y Kill Chain)

Fuerza Bruta vs. Password Spraying (Event ID 4625)

CARACTERÍSTICA	FUERZA BRUTA TRADICIONAL	PASSWORD SPRAYING
Patrón de Ataque	Miles de claves contra 1 solo usuario.	1 clave común contra cientos de usuarios.
TargetUserName	Idéntico en cada evento.	Diferente en cada evento.
Efecto en Dominio	Bloqueo inmediato de la cuenta (Account Lockout).	Silencioso, evadiendo políticas de bloqueo.
Contención	Bloqueo de IP y desbloqueo de cuenta.	Bloqueo de IP + Auditoría de Event ID 4624 (Logon exitoso).

Matriz de Event IDs Clave en la Cadena de Ataque

FASE MITRE ATT&CK	EVENT ID	INDICADORES CLAVE Y CAMPOS A AUDITAR
Movimiento Lateral	4624	Logon Type 3 (Red), Authentication Package: NTLM , proceso lsass.exe . Típico de Pass-the-Hash (PtH).
Privilege Escalation	4672	Privilegios especiales asignados (SeDebugPrivilege , SeImpersonatePrivilege) hacia NT AUTHORITY\SYSTEM .
Persistencia	4697 / 4698	Instalación de servicios o Tareas Programadas corriendo desde rutas de usuario (\AppData\Local\Temp\).
Exfiltración / C2	Network Logs	Tráfico saliente masivo por puerto 443/80 hacia IPs no reputadas inmediatamente tras ejecución en Temp .

3. Triage de Phishing y Encabezados de Email

Al analizar correos sospechosos reportados por usuarios, el análisis de cabeceras es el paso inicial antes de interactuar con enlaces o adjuntos.

Pilares de Autenticación de Correo:

- SPF (Sender Policy Framework):** Valida si la IP emisora está autorizada por el dominio remitente.
- DKIM (DomainKeys Identified Mail):** Firma criptográfica que garantiza la integridad del mensaje.
- DMARC:** Define la política (none , quarantine , reject) ante fallos de SPF/DKIM.

Triage de Adjuntos Maliciosos (Info-Stealers)

- Doble Extensión: Uso de trampas visuales como Factura_Pendiente.pdf.exe para engañar al usuario.
- Análisis Estático: Generación de hash SHA256 (Get-FileHash) y consulta en VirusTotal / Any.Run sin ejecutar el archivo.
- Acción Inmediata si se Ejecutó: Aislamiento del host vía EDR (*Host Isolation*), cambio forzado de credenciales y revocación de tokens de sesión activas.

4. Detección y Búsquedas SPL en SIEM (Splunk)

Búsqueda 1: Ejecución de Procesos en Carpetas Temporales (Sysmon 1 / Event 4688)

```
index=windows (EventCode=1 OR EventCode=4688)
| eval process_path=lower(Image)
| search process_path="*\appdata\local\temp\*" OR process_path="*\appdata\roaming\*"
| stats count min(_time) as primera_vez max(_time) as ultima_vez by host, User, Image, ParentImage, CommandLine
| convert ctime(primer_vez) ctime(ultima_vez)
```

Búsqueda 2: Detección de Doble Extensión de Archivo

```
index=windows (EventCode=1 OR EventCode=4688)
| search Image="*.pdf.exe" OR Image="*.doc.exe" OR Image="*.zip.exe" OR Image="*.xlsx.exe"
| table _time, host, User, Image, ParentImage, CommandLine
```

Matriz de Genealogía de Procesos (Process Lineage)

PROCESO PADRE (PARENTIMAGE)	PROCESO HIJO (IMAGE)	NIVEL DE RIESGO	DIAGNÓSTICO SOC
outlook.exe	cmd.exe / powershell.exe	CRÍTICO	Ejecución de script vía adjunto malicioso.
winword.exe / excel.exe	powershell.exe / wscript.exe	CRÍTICO	Documento de Office con macro maliciosa.
chrome.exe	update.exe (en AppData\Temp)	ALTO	Descarga maliciosa o Drive-by download.

Resumen de Playbook de Contención EDR / Firewall:

1. Aislamiento de Host (EDR): Aislar la máquina afectada de la red manteniendo la memoria RAM intacta para análisis forense.
2. Bloqueo Perimetral: Cargar IPs y Dominios C2 en las listas de bloqueo del Firewall, WAF y DNS Gateway.
3. Sanitización de Correo: Purgar el mensaje malicioso de todos los buzones de la organización.
4. Reset de Credenciales: Forzar el cambio de contraseña y la revocación de tokens de sesión para cuentas comprometidas.